

MODELO DE ENCUESTA INTEGRAL CAPEC-ESP 2026

Adopción, Indicadores y Métricas del Marco CAPEC en Organizaciones Españolas

Kit de Encuesta CAPEC-ESP • Documento A • Versión 1.0 • Abril 2026

«El adversario ya ha hecho sus deberes. Esta encuesta sirve para saber si los hemos hecho nosotros.»

INSTRUCCIONES GENERALES

Esta encuesta evalúa el grado de **conocimiento, adopción y uso de indicadores y métricas del marco CAPEC (Common Attack Pattern Enumeration and Classification) de MITRE** en organizaciones españolas, en el contexto del nuevo ecosistema regulatorio NIS2/ENS/DORA y las amenazas emergentes de 2025.

- Dirigida a: CISO, CTO, CRO, responsable de Seguridad de la Información, responsable de TI o equivalente con responsabilidad en ciberseguridad
- Tiempo estimado: 35–45 minutos
- Período de referencia: Actividades y capacidades 2024–2025
- Confidencialidad: Las respuestas se tratarán de forma anónima y agregada. No se publicarán datos identificativos de ninguna organización
- Instrucciones: Marque la opción que mejor describa la situación real de su organización. En las preguntas abiertas, la franqueza es siempre bienvenida —y la ironía, admitida con agrado

SECCIÓN 0 • PERFIL ORGANIZATIVO

No preguntamos quién es usted. Preguntamos qué rol interpreta en el teatro de operaciones digital de su organización.

P0.1 — Rol del respondente

¿Cuál es su rol principal en materia de ciberseguridad?

- ☐ CISO — Chief Information Security Officer
- ☐ CTO — Chief Technology Officer / Director de Tecnología
- ☐ CRO — Chief Risk Officer / Director de Riesgos
- ☐ CSO — Chief Security Officer / Director de Seguridad
- ☐ Responsable de SOC / Centro de Operaciones de Seguridad
- ☐ Responsable de Cumplimiento y GRC (Governance, Risk & Compliance)
- ☐ Arquitecto/a de Seguridad
- ☐ Director/a o Responsable de TI / Infraestructura
- ☐ Consultor/a externo/a con responsabilidad delegada en ciberseguridad
- ☐ Otro: _____

P0.2 — Sector de actividad principal

- ☐ Administración Pública (Estatal, Autonómica o Local)
- ☐ Banca / Servicios financieros
- ☐ Seguros y fondos de pensiones
- ☐ Energía (producción, transporte, distribución, suministro)
- ☐ Salud / Servicios sanitarios y hospitalarios
- ☐ Telecomunicaciones / Servicios digitales e infraestructura de red
- ☐ Transporte, logística e infraestructuras físicas
- ☐ Fabricación industrial / Industria 4.0 / Entornos OT
- ☐ Tecnología, software y servicios cloud
- ☐ Educación e investigación
- ☐ Retail, comercio y distribución
- ☐ Agua y gestión medioambiental
- ☐ Defensa y seguridad nacional
- ☐ Otro: _____

P0.3 — Tamaño de la organización (empleados en España)

- ☐ Menos de 50 — microempresa (la agilidad tiene su precio regulatorio)
- ☐ 50–249 — PYME pequeña
- ☐ 250–999 — PYME mediana
- ☐ 1.000–4.999 — empresa grande
- ☐ 5.000 o más — gran corporación o entidad pública relevante

P0.4 — Marcos normativos aplicables

Indique los marcos que le aplican actualmente (o que le aplicarán en los próximos 12 meses):

- ☐ ENS — Esquema Nacional de Seguridad (RD 311/2022)
- ☐ NIS2 — Directiva (UE) 2022/2555, como entidad esencial
- ☐ NIS2 — Directiva (UE) 2022/2555, como entidad importante
- ☐ DORA — Reglamento (UE) 2022/2554 (entidades financieras)
- ☐ RGPD / GDPR — Reglamento (UE) 2016/679
- ☐ ISO/IEC 27001:2022
- ☐ SOC 2 Type II
- ☐ PCI-DSS
- ☐ NERC-CIP (infraestructuras energéticas)
- ☐ Otro marco sectorial: _____
- ☐ Ninguno (bienvenido al universo paralelo de la ciberseguridad voluntaria)

P0.5 — Presupuesto de ciberseguridad sobre TI total

- ☐ Menos del 5% — la seguridad como epígrafe decorativo de la partida presupuestaria
- ☐ Entre el 5% y el 10% — rango habitual de mercado
- ☐ Entre el 10% y el 15% — por encima de la media sectorial
- ☐ Entre el 15% y el 20% — posicionamiento estratégico explícito
- ☐ Más del 20% — sector crítico o incidente reciente suficientemente convincente
- ☐ No lo sé / No se comparte internamente (lo cual es, en sí mismo, una respuesta)

SECCIÓN I • CONOCIMIENTO Y ADOPCIÓN DE CAPEC

CAPEC: ese catálogo que muchos frameworks citan, pocos leen y algunos valientes aplican con rigor.

P1.1 — Familiaridad personal con CAPEC

¿Cuál es su nivel personal de conocimiento del marco CAPEC v3.9 (559 patrones de ataque)?

- ☐ Muy alto — Trabajo con CAPEC de forma habitual; conozco su arquitectura, vistas y campos internos
- ☐ Alto — Conozco bien el catálogo y lo he utilizado en proyectos reales
- ☐ Medio — Conozco el concepto y la estructura básica; lo he consultado puntualmente
- ☐ Bajo — He oído el acrónimo y tengo una idea difusa de su utilidad
- ☐ Nulo — Esta encuesta es mi primera aproximación al tema (bienvenido/a; el camino empieza aquí)

P1.2 — Familiaridad organizativa con CAPEC

¿Cuál es el nivel de conocimiento de CAPEC en su organización más allá de usted?

- ☐ Amplia — CAPEC es conocido y referenciado fuera del equipo de seguridad
- ☐ Focalizada — Solo el equipo de ciberseguridad / desarrollo seguro lo maneja
- ☐ Puntual — Una o dos personas lo conocen; el resto, no
- ☐ Inexistente — Solo yo (si acaso) estoy familiarizado/a con el marco

P1.3 — Vistas y taxonomías CAPEC utilizadas

¿Con qué vistas o estructuras taxonómicas de CAPEC está familiarizado/a? *(Marque las que conozca o use)*

- ☐ Lista general CAPEC v3.9 completa (559 patrones, capec.mitre.org)
- ☐ Vista Mechanisms of Attack (CAPEC-1000): 9 categorías de mecanismo
- ☐ Vista Domains of Attack (CAPEC-3000): Software, Hardware, Comunicaciones, Supply Chain, Ingeniería Social, Físico
- ☐ Vista ICS/OT (CAPEC-703): Sistemas de Control Industrial
- ☐ Los cuatro niveles de abstracción: Categoría → Meta-Patrón → Patrón Estándar → Patrón Detallado
- ☐ Integración CAPEC → CWE (Common Weakness Enumeration) y CVE
- ☐ Integración CAPEC → MITRE ATT&CK y D3FEND
- ☐ Ninguna en particular

P1.4 — Indicadores internos de CAPEC utilizados

¿Qué campos/indicadores de cada entrada CAPEC utiliza su organización? *(Marque los que apliquen)*

- ☐ Typical_Severity — Severidad típica del impacto del patrón de ataque
- ☐ Likelihood_Of_Attack — Probabilidad relativa de que un adversario use este patrón
- ☐ Typical_Likelihood_Of_Exploit — Probabilidad de explotación exitosa
- ☐ Indicadores de Susceptibilidad Positivos — Condiciones que facilitan el ataque
- ☐ Indicadores de Susceptibilidad Negativos — Controles que dificultan el ataque
- ☐ Attacker Skills Required — Nivel de habilidad necesario del atacante
- ☐ Execution Flow — Fases del ataque (Exploration / Experimentation / Exploitation)
- ☐ Consecuencias sobre CIA — Confidencialidad, Integridad, Disponibilidad
- ☐ Mappings — Relaciones con CWE, CVE, ATT&CK, CAPEC padre/hijo
- ☐ No usamos campos específicos; solo la descripción narrativa del patrón
- ☐ No usamos CAPEC

P1.5 — Estado de implementación de CAPEC

¿En qué estado se encuentra la adopción formal de CAPEC en su organización?

- ☐ Implementación plena — CAPEC está integrado en procesos, herramientas y documentación formal de seguridad
- ☐ Implementación parcial — Se usa en algunos procesos pero no de manera sistemática
- ☐ Fase piloto o prueba de concepto — Lo estamos evaluando en proyectos selectivos
- ☐ En planificación — Existe intención formal de adoptarlo en los próximos 12 meses
- ☐ Sin implementación — CAPEC no está en la hoja de ruta actual
- ☐ Externalizado — La seguridad se gestiona con proveedores que pueden usarlo (o no; nunca hemos preguntado)

P1.6 — Procesos donde se aplica CAPEC

¿En qué procesos de su organización se utiliza CAPEC? *(Marque todos los que apliquen)*

- ☐ Modelado de amenazas formal (threat modeling)
- ☐ Evaluación y gestión de riesgos de ciberseguridad
- ☐ Desarrollo seguro de software / DevSecOps / SSDLC
- ☐ Pruebas de penetración / Red Team / Purple Team
- ☐ Auditorías de seguridad y evaluación de controles
- ☐ Inteligencia de amenazas (CTI / ISAC / threat feeds)
- ☐ Respuesta a incidentes y análisis forense
- ☐ Diseño de ejercicios de crisis (tabletop exercises)
- ☐ Gestión de proveedores y cadena de suministro
- ☐ Formación y concienciación del equipo técnico
- ☐ Ninguno de los anteriores

P1.7 — Herramientas de apoyo utilizadas

¿Qué herramientas usa su organización para trabajar con CAPEC u otros marcos de amenazas? (*Marque las que apliquen*)

- ☐ MITRE ATT&CK Navigator
- ☐ MITRE D3FEND
- ☐ PILAR / EAR (CCN-CNI — herramienta oficial de análisis ENS)
- ☐ IriusRisk
- ☐ ThreatModeler
- ☐ Microsoft Threat Modeling Tool
- ☐ OWASP Threat Dragon
- ☐ OpenCTI / MISP
- ☐ SIEM/XDR con integración ATT&CK o CAPEC
- ☐ Plataforma GRC con módulo de amenazas
- ☐ Desarrollos o scripts internos
- ☐ Ninguna herramienta específica
- ☐ Otra: _____

SECCIÓN II • MODELADO DE AMENAZAS

Un modelo de amenazas sin catálogo de patrones es una hipótesis sin datos. Interesante como ejercicio mental; peligroso como política de seguridad.

P2.1 — Metodologías de modelado de amenazas activas

¿Qué metodologías usa su organización formalmente? (*Marque todas las que apliquen*)

- ☐ STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege)
- ☐ PASTA (Process for Attack Simulation and Threat Analysis)
- ☐ OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)
- ☐ LINDDUN (orientado a privacidad y amenazas de datos personales)
- ☐ VAST (Visual, Agile, and Simple Threat modeling)
- ☐ DREAD (scoring multi-criterio)
- ☐ FAIR (cuantificación financiera del riesgo)
- ☐ MAGERIT / herramienta PILAR (metodología CCN para ENS)
- ☐ Metodología propia formalmente documentada
- ☐ No realizamos modelado de amenazas formal (también es una respuesta con consecuencias visibles)

P2.2 — Grado de integración CAPEC con el modelado

Si realiza modelado de amenazas, ¿cómo integra los patrones CAPEC?

- ☐ Integración total — CAPEC es el catálogo principal de amenazas de nuestra metodología
- ☐ Integración complementaria — Usamos CAPEC junto a ATT&CK u otras fuentes
- ☐ Integración selectiva — Consultamos CAPEC solo para dominios o proyectos específicos
- ☐ Referencia ocasional — Solo ante incidentes nuevos o que no encajan en el modelo previo
- ☐ Sin integración — No usamos CAPEC en el modelado

P2.3 — Cobertura de dominios CAPEC en el modelado

Indique el grado de cobertura de cada dominio en sus actividades de modelado de amenazas:

Dominio CAPEC (Vista 3000)	Sin cubrir	Cobertura mínima	Cobertura parcial	Cobertura amplia	Cobertura completa
Software (aplicaciones, APIs, web)	☐	☐	☐	☐	☐
Hardware (firmware, BIOS/UEFI, side-channel)	☐	☐	☐	☐	☐
Comunicaciones (protocolos, red, wireless)	☐	☐	☐	☐	☐
Cadena de Suministro (SW terceros, CI/CD)	☐	☐	☐	☐	☐
Ingeniería Social (phishing, deepfakes, BEC)	☐	☐	☐	☐	☐
Seguridad Física (acceso físico, jamming)	☐	☐	☐	☐	☐
ICS/OT (SCADA, PLCs, redes industriales)	☐	☐	☐	☐	☐

P2.4 — Frecuencia de actualización del modelo de amenazas

¿Con qué frecuencia se actualiza el modelo para incorporar nuevos patrones CAPEC o cambios en el panorama de amenazas?

- ☐ Continuamente — Integrado con fuentes de CTI en tiempo real o casi real
- ☐ Trimestralmente — Revisión sistemática cada tres meses
- ☐ Semestralmente — Revisión cada seis meses
- ☐ Anualmente — Revisión anual o vinculada a auditorías
- ☐ Ad hoc — Solo tras incidentes significativos o cambios mayores de infraestructura
- ☐ Nunca — El modelo no ha sido revisado desde su creación (lo que explica algunas cosas)

SECCIÓN III • INDICADORES Y MÉTRICAS CAPEC

Lo que no llega al dashboard del Consejo tiende a no existir —salvo el día después del incidente, que entonces existe con una nitidez insoportable.

P3.1 — Métricas basadas en CAPEC implementadas

¿Cuáles de estas métricas derivadas de CAPEC tiene implantadas su organización?

- ☐ Índice de Severidad Ponderada (ISP) — Suma de Typical_Severity × frecuencia por patrón detectado
- ☐ Cobertura de mecanismos de ataque — % de los 9 mecanismos CAPEC con al menos un control activo
- ☐ MTTD-CAPEC — Tiempo medio de detección segmentado por patrón de ataque
- ☐ MTTR-CAPEC — Tiempo medio de respuesta/recuperación por patrón
- ☐ Tasa de remediación de indicadores positivos — % de condiciones facilitadoras de ataque eliminadas
- ☐ Índice de exposición por dominio — Distribución de incidentes reales por dominio CAPEC
- ☐ Ratio de novedad de patrones — % de incidentes que implican patrones no cubiertos en el modelo previo
- ☐ Cobertura CVE-CAPEC — % del inventario de vulnerabilidades con mapeo a patrón CAPEC
- ☐ IGM-CAPEC — Índice Global de Madurez CAPEC (propio o derivado)
- ☐ Ninguna métrica específica basada en CAPEC
- ☐ Métricas propias no basadas en CAPEC: _____

P3.2 — Sistema de gestión y visualización de métricas

¿Cómo gestiona y visualiza su organización las métricas de ciberseguridad?

- ☐ Dashboard ejecutivo integrado — Panel directivo con métricas de seguridad actualizadas regularmente
- ☐ SIEM/XDR con mapeo ATT&CK/CAPEC — Correlación automática de eventos con marcos de amenazas
- ☐ Plataforma GRC — Sistema especializado con métricas, flujos de aprobación e informes normativos
- ☐ Herramientas de BI — Power BI, Tableau, Looker, Grafana con datos de seguridad
- ☐ Informes manuales periódicos — Word/Excel/PowerPoint elaborados manualmente
- ☐ Métricas ad hoc — Solo se generan ante incidentes o auditorías inminentes
- ☐ Sin sistema formal — Las métricas de ciberseguridad no están gestionadas de forma estructurada

P3.3 — Reporte al órgano de dirección (NIS2 Art. 20)

¿Con qué frecuencia se reportan métricas de ciberseguridad al Consejo de Administración o equivalente?

- ☐ Mensualmente — Métricas regulares integradas en el ciclo de reporting directivo
- ☐ Trimestralmente — Informe trimestral de postura de seguridad
- ☐ Semestralmente — Revisión semestral formal
- ☐ Anualmente — Un informe anual de estado de la ciberseguridad
- ☐ Solo ante incidentes — El Consejo recibe información reactiva (cuando ya el daño está hecho)
- ☐ Nunca — La ciberseguridad no se reporta formalmente al órgano de gobierno

P3.4 — Uso de indicadores CAPEC en la gestión de riesgos

¿Cómo incorpora su organización los indicadores `Typical_Severity` y `Likelihood_Of_Attack` de CAPEC en la gestión formal de riesgos?

- ☐ Integración cuantitativa — Alimentan directamente un modelo de riesgo financiero (FAIR, ALE, actuarial)
- ☐ Integración cualitativa — Informan matrices de riesgo probabilidad × impacto
- ☐ Referencia informativa — Se consultan para contextualizar riesgos sin incorporarlos formalmente
- ☐ No se incorporan — El modelo de riesgos no referencia indicadores CAPEC
- ☐ No aplicable — No se usa CAPEC

P3.5 — Autoevaluación del Índice de Madurez CAPEC (IGM) por dominio

Valore el nivel de madurez de su organización en cada dominio (1 = inexistente → 5 = optimizado en mejora continua):

Dominio CAPEC	1 Inexistente	2 Inicial	3 Definido	4 Gestionado	5 Optimizado
Software (aplicaciones, APIs, web)	☐	☐	☐	☐	☐
Hardware (firmware, BIOS, side-channel)	☐	☐	☐	☐	☐
Comunicaciones (protocolos, red, wireless)	☐	☐	☐	☐	☐
Cadena de Suministro (SW terceros, CI/CD)	☐	☐	☐	☐	☐
Ingeniería Social (phishing, deepfakes, BEC)	☐	☐	☐	☐	☐
Seguridad Física (acceso, tailgating, jamming)	☐	☐	☐	☐	☐
ICS/OT (SCADA, PLCs, redes industriales)	☐	☐	☐	☐	☐

P3.6 — Tres brechas prioritarias de cobertura

¿En qué áreas identifica las mayores brechas respecto a los patrones CAPEC? (*Seleccione las tres más críticas*)

- ☐ Ataques de IA / LLM (prompt injection, model poisoning) — el más nuevo y menos mapeado en el catálogo
- ☐ Cadena de suministro de software (Repo Jacking, CI/CD poisoning, CAPEC-437/538/695)
- ☐ Ingeniería social avanzada (deepfakes, vishing con IA, BEC sofisticado)
- ☐ Entornos ICS/OT (sistemas industriales y de control)
- ☐ Hardware y firmware (BIOS/UEFI, firmware de red, supply chain hardware)
- ☐ Amenazas cuánticas (HNDL, criptografía vulnerable, post-quantum readiness)
- ☐ Exfiltración de datos por canales encubiertos o side-channel
- ☐ Servicios cloud, multi-cloud, SaaS y gestión de APIs
- ☐ Movimiento lateral en entornos Zero Trust o híbridos
- ☐ Ataques a infraestructura de identidad (CAPEC-21, credential abuse, token theft)

SECCIÓN IV · AMENAZAS EMERGENTES 2025

El pasado ataca con métodos conocidos. El futuro lo hace con los que aún no hemos catalogado. Y el presente —con notable crueldad— emplea ambos simultáneamente.

P4.1 — Incidentes de IA como vector de ataque (últimos 24 meses)

¿Ha detectado su organización alguno de los siguientes tipos de ataque potenciados por IA?

- ☐ Phishing generado con IA — Mensajes hiperpersonalizados, sin los errores habituales de ortografía que antes delatan al atacante
- ☐ Deepfake de video o audio — Suplantación de ejecutivos o empleados en comunicaciones internas o externas
- ☐ Vishing con voz sintética — Llamadas fraudulentas con voz clonada de personas reales de la organización
- ☐ SEO Poisoning asistido por IA — Envenenamiento de búsquedas para redirigir a páginas maliciosas
- ☐ Prompt Injection contra LLMs corporativos — Manipulación de asistentes de IA internos para eludir controles
- ☐ BEC (Business Email Compromise) potenciado con IA — Fraude de transferencia con suplantación convincente
- ☐ Reconocimiento OSINT automatizado — Uso de IA para perfilado masivo previo al ataque dirigido
- ☐ Evasión de sistemas de detección — Técnicas adversariales para burlar EDR/XDR/SIEM
- ☐ Ninguno detectado en nuestros sistemas (que sepamos; la diferencia no es trivial)
- ☐ No monitorizamos estos vectores específicamente

P4.2 — Controles frente a ataques adversariales a sistemas de IA (NIST AI 100-2e2025)

Valore la madurez de sus controles (1 = sin control – 4 = control definido, probado y monitorizado):

Tipo de Ataque Adversarial	1 Sin control	2 Planificado	3 Parcial	4 Pleno
Evasion Attack (perturbaciones en inferencia)	☐	☐	☐	☐
Poisoning Attack (corrupción de datos de entrenamiento)	☐	☐	☐	☐
Model Extraction (replicación del modelo por inferencia)	☐	☐	☐	☐
Backdoor / Trojan Attack (trigger oculto en modelo)	☐	☐	☐	☐
Prompt Injection (manipulación de instrucciones en LLMs)	☐	☐	☐	☐
Shadow AI Data Exfiltration (filtración por IA no autorizada)	☐	☐	☐	☐

P4.3 — Política corporativa de IA generativa

¿Dispone su organización de una política formal sobre el uso de herramientas de IA generativa?

- ☐ Sí, política completa — Cubre uso permitido, datos prohibidos, clasificación de herramientas, controles DLP y revisión periódica
- ☐ Sí, política básica — Existe una política pero con lagunas en cobertura de riesgos de seguridad
- ☐ En elaboración — El comité trabaja en ello (mientras el modelo es más rápido que el proceso)
- ☐ Solo directrices informales — Comunicados internos sin formalización
- ☐ Prohibición total — El uso de IA generativa está prohibido (y todos usamos ChatGPT en el móvil personal)
- ☐ Sin política — Cada área improvisa según criterio propio

P4.4 — Seguridad en la cadena de suministro de software (NIS2 Art. 21.2.d)

¿Qué prácticas tiene implantadas para mitigar patrones CAPEC de supply chain? (Marque las que apliquen)

- ☐ SBOM (Software Bill of Materials) — Inventario completo y actualizado de componentes de software de terceros
- ☐ SCA (Software Composition Analysis) — Escaneo automático de dependencias en entorno de desarrollo y CI/CD
- ☐ Verificación de integridad de artefactos — Firma criptográfica y verificación en pipelines CI/CD
- ☐ Auditoría periódica de proveedores de software crítico — Evaluación de seguridad formal
- ☐ Hardening de pipelines CI/CD — SAST, DAST, secret scanning y control de acceso mínimo en pipelines
- ☐ Monitorización de repositorios de paquetes — Alertas sobre cambios sospechosos en paquetes de producción
- ☐ Allowlist / Denylist de dependencias — Política de dependencias de software aprobadas
- ☐ Evaluación de riesgo de terceros TIC (DORA Art. 28) — Para entidades bajo DORA
- ☐ Cláusulas contractuales de seguridad — Requisitos de seguridad en contratos con proveedores de software
- ☐ Ninguna práctica específica — La cadena de suministro SW es territorio sin cartografía en nuestra organización

P4.5 — Incidentes de cadena de suministro (últimos 24 meses)

¿Ha experimentado su organización algún incidente de supply chain de software?

- ☐ Sí, incidente confirmado con impacto — Compromiso real de sistemas o datos a través de un proveedor
- ☐ Sí, incidente detectado y contenido — Se identificó el vector antes de que causara daño
- ☐ Sospecha no confirmada — Indicios que no se pudieron atribuir con certeza
- ☐ No, que sepamos (y reconocemos el peso de esas tres últimas palabras)
- ☐ En investigación activa — Actualmente se analiza un posible incidente de este tipo

P4.6 — Preparación ante amenazas cuánticas (Post-Quantum Readiness)

¿En qué estadio se encuentra su organización respecto a la preparación criptográfica ante computación cuántica?

- ☐ Programa activo de migración PQC — En transición hacia algoritmos NIST PQC (ML-KEM, ML-DSA, SLH-DSA)
- ☐ Inventario criptográfico completado — Identificados todos los algoritmos vulnerables (RSA, ECC, DH) en producción
- ☐ Evaluación de crypto-agility en curso — Assessment del parque criptográfico sin plan de migración aún
- ☐ En agenda estratégica — El tema está en el roadmap pero sin actuaciones formales iniciadas
- ☐ Conscientes del riesgo, sin acción — Lo sabemos; lo posponemos; alguien decidirá
- ☐ No considerado — La computación cuántica no está en nuestro radar de riesgos (aunque el adversario ya está cosechando)

P4.7 — Estrategia HNDL (Harvest Now, Decrypt Later)

¿Tiene su organización una estrategia para mitigar el riesgo de captura de tráfico cifrado para su descifrado posterior con capacidad cuántica?

- ☐ Sí, estrategia documentada y activa — Incluye clasificación de datos sensibles de larga vida, análisis de riesgo HNDL y plan de migración criptográfica con fecha
- ☐ En desarrollo — Evaluamos el riesgo y elaboramos la estrategia de respuesta
- ☐ Conscientes sin medidas formales — Hemos debatido el tema; la acción espera presupuesto
- ☐ No contemplado — Esta amenaza no figura en nuestro modelo de riesgo activo

SECCIÓN V • CUMPLIMIENTO REGULATORIO Y MARCO NORMATIVO

NIS2, ENS, DORA... El regulador ha pasado de murmurar a gritar. Queda por ver si las organizaciones escuchan o simplemente instalan mejores tapones para los oídos.

P5.1 — Mapeo ENS ↔ CAPEC

Si su organización está sujeta al ENS, ¿ha realizado un mapeo entre controles ENS y patrones CAPEC?

- ☐ Sí, mapeo completo documentado — Cada control ENS está vinculado a los patrones CAPEC que mitiga
- ☐ Sí, mapeo parcial — Solo para los controles más críticos o de mayor riesgo
- ☐ En proceso — El mapeo está en desarrollo actualmente
- ☐ No, pero lo consideramos necesario — El valor es reconocido; el tiempo, escaso
- ☐ No aplicable — Nuestra organización no está bajo el ámbito del ENS

P5.2 — Impacto de NIS2 en la gestión de patrones de ataque (NIS2 Art. 21)

¿Cómo ha impactado NIS2 en el uso de marcos de patrones de ataque como CAPEC?

- ☐ Impacto significativo — NIS2 ha sido el catalizador para formalizar el uso de CAPEC en nuestra gestión de amenazas
- ☐ Impacto moderado — NIS2 ha reforzado prácticas ya existentes, incluyendo referencias a marcos de amenazas
- ☐ Impacto marginal — NIS2 genera trabajo documental pero no ha cambiado el enfoque de amenazas
- ☐ Sin impacto aún — Aún procesando los requisitos del Art. 21 (hay lista de espera)
- ☐ No aplica — Nuestra organización no está en el ámbito de NIS2

P5.3 — Coordinación con INCIBE-CERT y CCN-CERT

¿Qué nivel de coordinación mantiene su organización con los organismos nacionales de ciberseguridad?

- ☐ Coordinación activa y bidireccional — Participamos en intercambio de inteligencia de amenazas con INCIBE-CERT y/o CCN-CERT
- ☐ Recepción sistemática de alertas — Recibimos boletines y alertas pero no contribuimos activamente
- ☐ Coordinación ad hoc — Solo contacto ante incidentes graves
- ☐ Sin coordinación formal — No existe relación estructurada con organismos nacionales
- ☐ Relación en construcción — Iniciando contactos y protocolos de coordinación

P5.4 — Clasificación CAPEC en la notificación de incidentes

Cuando notifica incidentes al regulador competente, ¿incluye la clasificación del patrón de ataque según CAPEC?

- ☐ Sí, siempre — Nuestros informes de incidente incluyen el patrón CAPEC correspondiente cuando es identificable
- ☐ Sí, cuando es determinable — El análisis forense define el patrón; si no hay certeza, no se incluye
- ☐ No, pero lo consideraríamos útil — La idea tiene mérito; el procedimiento aún no
- ☐ No — Nuestros informes de incidente no incluyen clasificación CAPEC
- ☐ No aplicable — No estamos sujetos a obligación formal de notificación de incidentes

SECCIÓN VI • RESILIENCIA DIGITAL Y CONTINUIDAD DE NEGOCIO

La resiliencia no es lo que haces cuando el sistema cae. Es lo que habrás construido con suficiente antelación para que el sistema tenga algo a lo que volver.

P6.1 — Integración de CAPEC en BCP/DRP

¿Está CAPEC integrado en sus planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP)?

- ☐ Integración plena — Los escenarios de BCP/DRP se definen sobre patrones CAPEC de alta severidad para nuestro sector
- ☐ Integración parcial — Algunos escenarios de continuidad referencian tipos de ataque sin mapeo explícito a CAPEC
- ☐ Sin integración formal — Los planes usan escenarios genéricos (fallo técnico, desastre natural) sin amenaza intencionada
- ☐ No disponemos de BCP/DRP formal (declaración valiente en el contexto regulatorio actual)

P6.2 — Tabletop Exercises basados en escenarios CAPEC

¿Con qué frecuencia realiza su organización ejercicios de simulación basados en escenarios de patrones de ataque?

- ☐ Mensualmente — Ejercicios frecuentes; alta madurez operacional
- ☐ Trimestralmente — Ritmo que equilibra rigor y sostenibilidad
- ☐ Semestralmente
- ☐ Anualmente — El mínimo que exige la cordura regulatoria
- ☐ Solo ante cambios regulatorios o incidentes significativos — El modelo reactivo
- ☐ Nunca — Los simulacros se reservan para los bomberos

P6.3 — Métricas de resiliencia por patrón de ataque

¿Dispone su organización de métricas de resiliencia definidas y medidas para los principales patrones de ataque?

Métrica de Resiliencia	No definida	Definida, no medida	Definida y medida	Definida, medida y mejorada
RTO (Recovery Time Objective)	☐	☐	☐	☐
RPO (Recovery Point Objective)	☐	☐	☐	☐
MTTD (Mean Time To Detect)	☐	☐	☐	☐
MTTR (Mean Time To Respond/Recover)	☐	☐	☐	☐
Tasa de detección (% ataques detectados antes de impacto)	☐	☐	☐	☐
Tasa de contención (% ataques sin propagación)	☐	☐	☐	☐

P6.4 — Participación en ejercicios nacionales o europeos

¿Ha participado en ciberejercicios de ámbito nacional o europeo (INCIBE, CCN-CERT, CyberEurope ENISA) en los últimos 24 meses?

- ☐ Sí, como participante activo — Con escenarios formales de ataque definidos
- ☐ Sí, como observador — Sin participación activa en los escenarios
- ☐ No, pero tenemos intención de participar
- ☐ No — No hemos participado en este tipo de ejercicios

SECCIÓN VII • GESTIÓN DE RIESGOS Y CUANTIFICACIÓN

El riesgo que no tiene euros al lado se gestiona con la misma precisión que el tiempo con un calendario maya: se intuye, se reza y se espera que el apocalipsis no sea hoy.

P7.1 — Metodología de cuantificación del riesgo cibernético

¿Qué metodología utiliza su organización para cuantificar el riesgo cibernético? (Marque las que apliquen)

- ☐ FAIR — Factor Analysis of Information Risk (valor monetario esperado de pérdida)
- ☐ CVSS — Common Vulnerability Scoring System (puntuación técnica)
- ☐ DREAD — Scoring multi-criterio (Damage, Reproducibility, Exploitability, Affected Users, Discoverability)
- ☐ Matriz de riesgo cualitativa — Probabilidad × Impacto en escala ordinal
- ☐ Puntuación CAPEC interna — Combinación de Likelihood_Of_Attack × Typical_Severity
- ☐ EPSS — Exploit Prediction Scoring System (probabilidad de explotación en 30 días)
- ☐ Modelo actuarial propio — Basado en estadísticas de siniestralidad propia o sectorial
- ☐ Sin metodología formal — La gestión de riesgos es más arte que ciencia en nuestra organización
- ☐ Otra: _____

P7.2 — Justificación del ROI de ciberseguridad ante la dirección

¿Cómo justifica ante la dirección el retorno de inversión de los controles de seguridad?

- ☐ Cuantificación del riesgo evitado — Calculamos el ALE (Annualized Loss Expectancy) sin y con control
- ☐ Reducción de exposición a patrones CAPEC — Medimos la reducción de exposición a patrones específicos
- ☐ Benchmarking sectorial — Comparamos inversión con el sector para argumentar proporcionalidad
- ☐ Cumplimiento regulatorio — La justificación principal es evitar sanciones NIS2/DORA/RGPD
- ☐ Coste de incidentes pasados — El historial propio como referencia de riesgo real
- ☐ Sin modelo formal de ROI — La inversión se justifica por presión regulatoria o precedente presupuestario

P7.3 — Cálculo del coste total de incidentes (últimos 12 meses)

¿Ha calculado el coste total de los incidentes de ciberseguridad?

- ☐ Sí, con metodología completa — Incluye costes directos, indirectos, reputacionales y regulatorios
- ☐ Sí, solo costes directos — Remediación técnica y respuesta al incidente
- ☐ Estimación aproximada — Un número, sin rigor metodológico formal
- ☐ No — No se calcula el coste de los incidentes (lo que imposibilita cualquier ROI honesto)

SECCIÓN VIII • PERSONAS, FORMACIÓN Y CULTURA

Los patrones CAPEC entran por donde dejan entrar los patrones humanos. Y ahí, en ese punto de fricción, se libra la batalla que más importa.

P8.1 — Formación específica en CAPEC y modelado de amenazas

¿Recibe el equipo de ciberseguridad formación específica en CAPEC y metodologías de modelado de amenazas?

- ☐ Programa anual estructurado — Con evaluación, actualización y plan de desarrollo individual
- ☐ Formación puntual — Ligada a proyectos o necesidades específicas
- ☐ Autoformación — El equipo aprende por iniciativa propia, sin programa institucional
- ☐ Sin formación específica en CAPEC
- ☐ Dependemos de consultores externos — El conocimiento reside fuera, no en el equipo propio

P8.2 — Concienciación en ingeniería social avanzada

¿Qué nivel de programa de concienciación tiene el personal no técnico en patrones de ingeniería social?

- ☐ Programa completo con métricas — Simulacros de phishing/vishing/deepfakes + tasas de respuesta + mejora demostrable año a año
- ☐ Formación anual sin simulaciones — Sensibilización general sobre técnicas de manipulación
- ☐ Solo formación de onboarding — Una sesión al incorporarse; nadie recuerda los detalles
- ☐ Sin programa formal — La concienciación depende de la iniciativa individual

P8.3 — Impacto de la brecha de talento en la adopción de CAPEC

¿Qué impacto tiene la escasez de perfiles especializados en ciberseguridad?

- ☐ Impacto crítico — Es el principal obstáculo para implementar marcos avanzados de amenazas
- ☐ Impacto significativo — Tenemos posiciones sin cubrir que dificultan directamente la adopción
- ☐ Impacto moderado — Nos afecta pero no es el principal obstáculo
- ☐ Impacto mínimo — Contamos con equipo suficientemente capacitado o hemos logrado retenerlo
- ☐ Lo compensamos con externalización — MSSP, consultoría o SOC compartido

SECCIÓN IX • ZERO TRUST Y ARQUITECTURAS MODERNAS

Zero Trust: porque "dentro" y "fuera" son conceptos que un atacante con credenciales válidas encuentra profundamente irrelevantes.

P9.1 — Estado de implementación de Zero Trust Architecture (ZTA)

¿En qué estadio se encuentra la implementación de Zero Trust en su organización?

- ☐ Arquitectura ZTA completa — Verificación continua de identidad, dispositivo y contexto; sin confianza implícita residual
- ☐ Implementación avanzada — ZTA en segmentos críticos: identidad, workloads cloud, acceso remoto
- ☐ Implementación parcial — Primeros pilares en producción (MFA universal, microsegmentación, SASE)
- ☐ En planificación — Hoja de ruta formal sin implementación iniciada
- ☐ Arquitectura perimetral clásica — El modelo de seguridad sigue siendo principalmente basado en el perímetro
- ☐ Arquitectura híbrida sin estrategia definida — La realidad operativa supera al diseño teórico

P9.2 — Evaluación de patrones CAPEC relevantes en entornos ZTA

¿Ha evaluado su organización los patrones CAPEC más relevantes para el contexto Zero Trust?

Patrón CAPEC (crítico en ZTA)	No evaluado	Evaluado, sin control	Control parcial	Control pleno
CAPEC-21 — Abuse of Trusted Credentials	☐	☐	☐	☐
CAPEC-633 — Token Impersonation / Theft	☐	☐	☐	☐
CAPEC-194 — Fake the Source of Data	☐	☐	☐	☐
CAPEC-22 — Exploiting Trust in Client	☐	☐	☐	☐
CAPEC-560 — Use of Known Domain Credentials	☐	☐	☐	☐
CAPEC-196 — Session Credential Falsification	☐	☐	☐	☐

SECCIÓN X • PERSPECTIVA ESTRATÉGICA

Aquí ya no preguntamos por "qué hay". Preguntamos por "qué quiere que haya" — que es la pregunta que distingue al estratega del técnico, y al líder del gestor.

P10.1 — Principales obstáculos para la adopción de CAPEC

¿Cuáles son los obstáculos más significativos? (Seleccione los tres más relevantes)

- ☐ Desconocimiento del marco en el equipo de seguridad
- ☐ Percepción de excesiva complejidad o granularidad
- ☐ Falta de herramientas que integren CAPEC en los flujos de trabajo habituales
- ☐ Escasez de tiempo y recursos humanos
- ☐ Falta de patrocinio directivo o priorización en la agenda del CISO/Consejo
- ☐ Preferencia consolidada por otros marcos (ATT&CK, CVSS, ISO 27005)
- ☐ Ausencia de requisito normativo explícito (CAPEC no está mandado directamente)
- ☐ No se percibe valor diferencial respecto a marcos ya utilizados
- ☐ Incapacidad para encontrar talento que lo opere con rigor

P10.2 — Valor percibido de CAPEC para su organización

En una escala del 1 al 5:

- ☐ 1 — Sin valor diferencial respecto a otros marcos disponibles
- ☐ 2 — Valor teórico pero escasa aplicabilidad práctica en nuestro contexto
- ☐ 3 — Valor moderado como complemento a ATT&CK y CVSS
- ☐ 4 — Valor estratégico significativo para la gestión de amenazas y riesgos
- ☐ 5 — CAPEC es o debería ser un pilar fundamental de nuestra estrategia de seguridad

P10.3 — Objetivo de su organización respecto a CAPEC en los próximos 12 meses

- ☐ Iniciar la adopción formal — Incorporar CAPEC en al menos un proceso de seguridad
- ☐ Ampliar la cobertura — Extender el uso actual a nuevos dominios y procesos
- ☐ Completar la integración — Alcanzar implementación plena en todos los procesos relevantes
- ☐ Mantenimiento del nivel actual — Conservar el estado actual y actualizar con nuevas versiones CAPEC
- ☐ Sin cambios previstos — El nivel actual se considera suficiente (con toda la responsabilidad que eso implica)

P10.4 — Recomendación al Centro Nacional de Ciberseguridad (CNC)

Si pudiera formular **una sola recomendación** al nuevo Centro Nacional de Ciberseguridad español sobre la integración de CAPEC en la estrategia nacional, ¿cuál sería?

(Respuesta abierta — Su perspectiva directa tiene un valor que ningún algoritmo puede sustituir)

P10.5 — Observaciones finales

¿Desea añadir alguna reflexión sobre el estado de la ciberseguridad basada en patrones de ataque en su organización o en España?

(Respuesta abierta — El rigor científico aprecia la franqueza; el cinismo constructivo, también)

CONSENTIMIENTO Y CIERRE

Al completar esta encuesta, usted declara que:

1. Las respuestas reflejan con fidelidad razonable la situación de su organización en 2024–2025
2. Comprende que los datos se tratarán de forma **anónima y exclusivamente agregada**

3. No ha revelado información clasificada ni protegida por acuerdos de confidencialidad
4. Acepta la publicación de resultados agregados con fines de investigación académica e institucional

Fecha de cumplimentación: _ / __ / 2026

Kit de Encuesta CAPEC-ESP · Documento A: Modelo de Encuesta Integral · Versión 1.0 · Abril 2026

Basado en: MITRE CAPEC v3.9 · ENS RD 311/2022 · NIS2 (UE) 2022/2555 · DORA (UE) 2022/2554 · ENISA ETL 2025 · NIST AI 100-2e2025 · INCIBE Balance Ciberseguridad España 2025